

Gartner® Magic Quadrant™ for Cyberthreat Intelligence Technologies

ReliaQuest named a Visionary.

[Access Now](#)

RESOURCE CENTER > BLOG

What's Trending: Top Cyber Attacker Techniques, December 2025–February 2026

RELIAQUEST THREAT RESEARCH₂ APRIL 2026

EMERGING THREATS

THREAT INTELLIGENCE

THREAT RESEARCH

**RELIAQUEST®**

Threat Research

***Editor's note:** This report was authored by James Xiang.*

Key Points

- This reporting period, trust is the key attack surface. **“Baoloader”** held the top spot at 40.9% of all malware incidents and **“ClickFix”** drove over 44% of defense evasion activity, both by exploiting what organizations already trust.
- In ransomware, groups **“Qilin”** and **“Akira”** thrived on unpatched infrastructure while extortion group **“ShinyHunters”** proved a single stolen single sign-on (SSO) session can rival full network encryption in impact.
- Defenders should prioritize ClickFix-specific user training, enforce remote monitoring and management (RMM) tool allowlists, centralize software-as-a-service (SaaS) audit logging, and treat internet-facing appliances as requiring emergency patch timelines.

Between December 1, 2025, and February 28, 2026 (“the reporting period”), the most impactful threats we observed had one thing in common: Attackers exploited trusted tools, identities, and user behavior rather than relying on technical sophistication. “ClickFix” accounted for the largest share of malware incidents, while remote monitoring and management (RMM) tools became the preferred command-and-control (C2) channel. “ShinyHunters” demonstrated that just one stolen single sign-on (SSO) session can match the impact of traditional encryption-based extortion, and ransomware groups “Akira” and “Qilin” maintained high operational tempo by exploiting the persistent gap between patch availability and patch deployment.

Attackers this reporting period leaned into two parallel strategies: social engineering at scale and exploitation of unpatched, internet-facing infrastructure. ClickFix continued to drive the social engineering front through search engine optimization (SEO) poisoning and compromised legitimate websites, while ShinyHunters evolved with branded subdomain impersonation and phone-guided adversary-in-the-middle (AiTM) phishing. On the exploitation front, CVE-2026-1731, a critical remote code execution (RCE) vulnerability, was weaponized and confirmed in active ransomware campaigns within two weeks of disclosure.

To respond, defenders must close the gap between phishing awareness and ClickFix-specific user training, treat legitimate tools and identity sessions as potential attack surfaces that require active monitoring, and accelerate patch timelines for internet-facing infrastructure as the window between disclosure and exploitation continues to shrink.

Read on to learn:

- Why ransomware operators like “LeakNet” are running ClickFix campaigns directly instead of purchasing access from brokers
- What the rise of non-traditional RMM tools in intrusions means for organizations whose detections are tuned to established platforms

- How ShinyHunters is scaling identity-first intrusions through paid vishing contractors, mobile-first lures, and the reuse of previously stolen software-as-a-service (SaaS) records to repeatedly target the same organizations

Malware and RMM Tool Trends

BaoLoader Leads Malware as Drive-By Compromise Continues to Deliver

“BaoLoader” retained its position as the top malware this period, accounting for **40.9%** of incidents—[an unusual level of consistency](#) in a landscape where malware families typically rotate between quarters. Its sustained dominance is closely tied to drive-by compromise, in which malvertising and compromised websites masquerade as legitimate productivity tools, so users encounter the Baoloader payload through ordinary browsing rather than a suspicious inbound message.

This distinction is important, because when users “find” something themselves, there’s an inherent sense of trust that lowers their guard. We saw the same trust-based dynamic play out elsewhere this period, which we’ll explore further in the next section.

We assess that the US tax season likely amplified this pattern, as users are more likely to search for financial tools and PDF editors (Baoloader’s typical disguise), expanding the pool of potential victims.

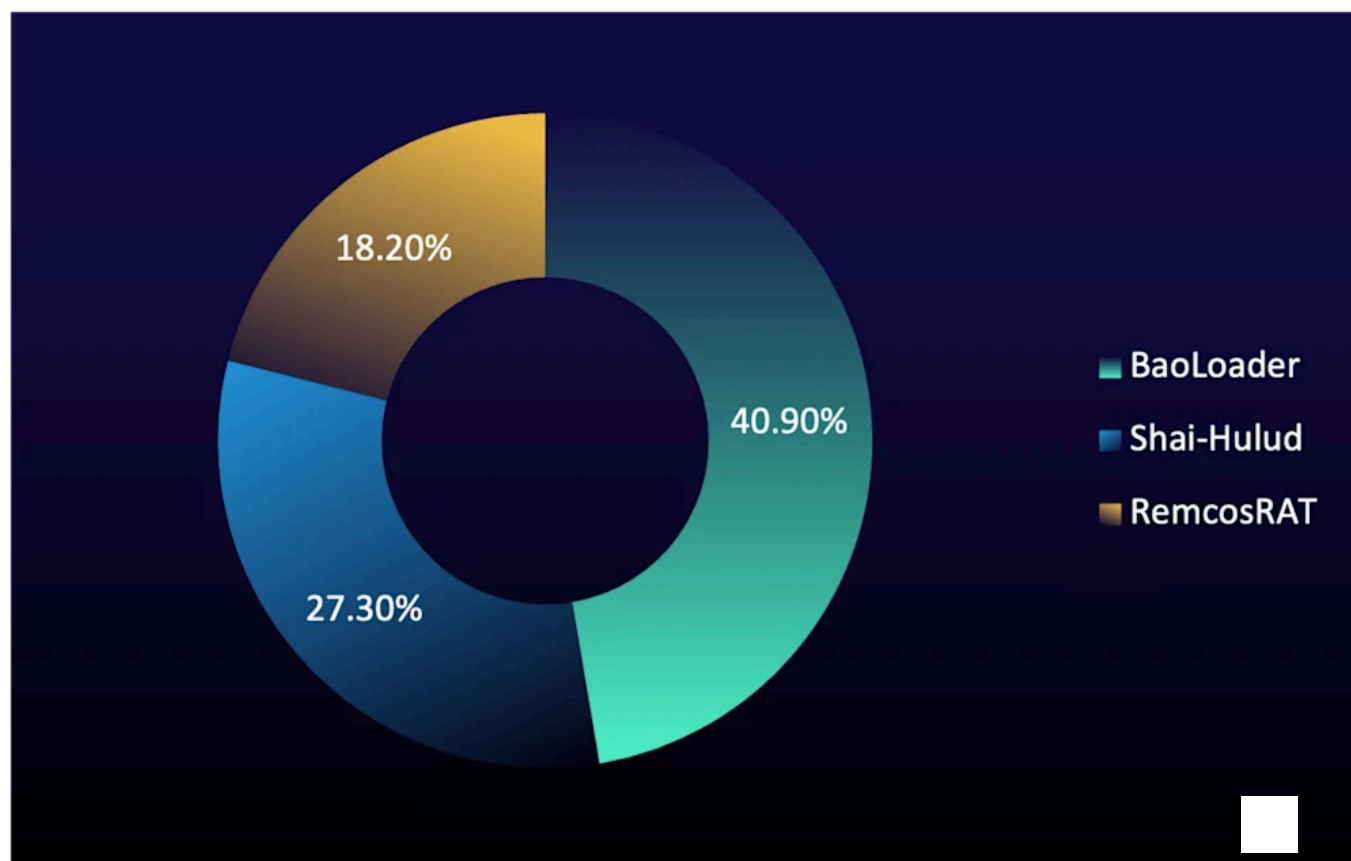


Figure 1: Top malware in true-positive incidents (% of total) during reporting period

In second place was the broader **“Shai-Hulud”** malware family at **27.3%**, which was the most significant new entry this period. Originally identified as an npm supply-chain worm in September 2025, “Shai-Hulud 2.0” expanded into cloud credential theft, moving from developer toolchain compromise to direct enterprise infrastructure risk. Its self-replicating nature makes containment particularly difficult once it enters a development pipeline.

“RemcosRAT” held third at **18.2%**, maintaining its long-standing presence as a prevalent commodity remote-access trojan (RAT) that’s delivered through phishing and fileless PowerShell execution.

The broader pattern is a shift in how malware reaches victims. Drive-by compromise, supercharged by ClickFix as a delivery technique, has overtaken traditional email-based delivery as the primary infection vector. ClickFix adoption continues to expand across the attacker spectrum, with ransomware operators like [LeakNet now using ClickFix lures to run campaigns](#) directly rather than purchasing access from initial access brokers (IABs).

For defenders, BaoLoader's consistency across two periods reinforces that email-centric detection strategies alone are insufficient. Organizations should monitor for software installations from unverified sources, implement application allowlists, and extend user awareness training to cover the risks of self-sourced downloads. For organizations with development teams using public package registries, the emergence of Shai-Hulud also emphasizes the need to treat dependency audits, package integrity checks, and monitoring for anomalous repository activity as security fundamentals.

RMM Tool Abuse: A Growing C2 Vector

RMM tool abuse remains a reliable C2 method for threat actors, because these tools are typically deployable en masse, provide direct graphic user interface (GUI) access, and are widely used by legitimate enterprise IT teams. Combined, this makes malicious misuse difficult to distinguish from normal administrative activity.

Trojanized ScreenConnect Abuse

ConnectWise ScreenConnect led RMM-related incidents this period at **25%**, but not in the typical RMM post-compromise pattern. Rather than deploying ScreenConnect post-compromise during hands-on-keyboard activity, we observed trojanized versions of the tool being dropped directly onto hosts, often through drive-by compromise. These modified builds connect back to attacker-controlled relay domains instead of legitimate ConnectWise infrastructure, effectively turning a trusted remote-access tool into a malware delivery payload.

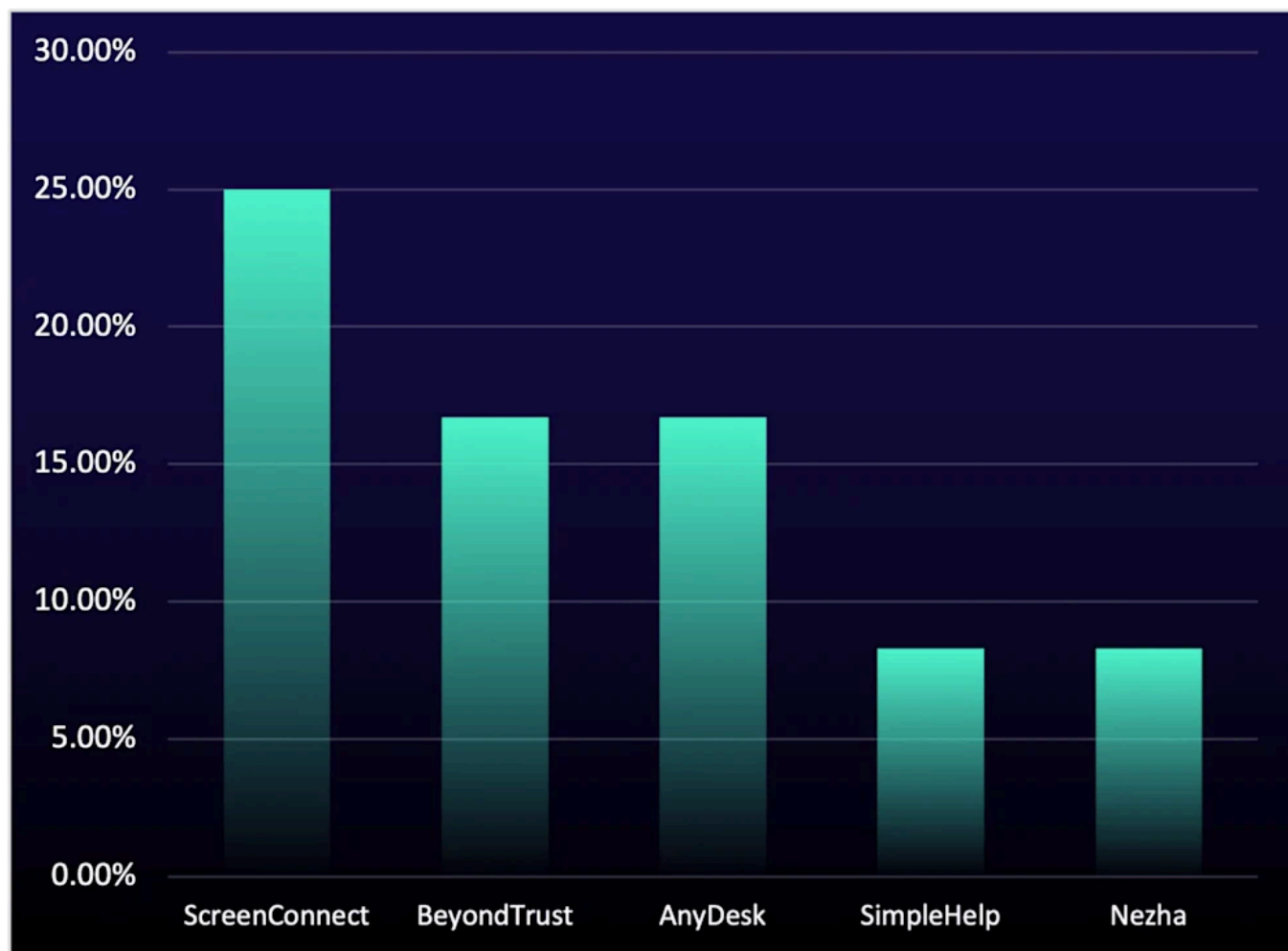


Figure 2: Top RMM tools in true-positive incidents (% of total) during reporting period

This reflects the same trust-based delivery dynamic that sustained BaoLoader this period, in which attackers place trojanized software where users would expect to find legitimate tools and rely on the target to initiate the infection themselves, typically through drive-by compromise.

Traditional RMM Abuse

BeyondTrust (formerly Bomgar), a remote support and privileged access management platform commonly used by IT help desks and managed service providers (MSPs), appeared in **16.7%** of RMM-related incidents. Its presence this period is connected to **CVE-2026-1731**, a critical pre-authentication RCE vulnerability (CVSS 9.9) in BeyondTrust Remote Support and Privileged Remote Access disclosed in February 2026. Exploitation of the flaw was confirmed in the wild within days of disclosure, and attackers used compromised BeyondTrust instances for both initial access and persistent remote access.

SimpleHelp and Nezha each accounted for **8.3%** of incidents, which likely reflects a deliberate shift by ransomware groups toward less common RMM tools that likely fall outside many organizations' existing detection coverage. Most organizations have built alerting around established platforms such as ConnectWise or AnyDesk; tools with smaller install bases often lack dedicated signatures or behavioral baselines, giving attackers a window of visibility that more familiar tools no longer provide.

For defenders, RMM tool monitoring can't be a static list of "known-bad" tools. Treat any unauthorized RMM installation as a high-priority alert, maintain strict allowlists for approved

remote-access software, and ensure that detection logic accounts for both legitimate tools connecting to unauthorized infrastructure and unfamiliar tools appearing on endpoints for the first time.

Step Up Your Defenses

- **Prioritize ClickFix-Specific User Training:** Train users to recognize and report requests to paste commands into system dialogs, and conduct simulations that replicate ClickFix-style lures alongside conventional phishing exercises.
- **Hunt for Command Obfuscation Techniques:** Prioritize detections that flag anomalous parent-child process relationships over static signature matching.
- **Audit and Enforce RMM Tool Allowlists:** Maintain a strict allowlist of approved remote-access software and treat any unauthorized RMM tool installation as a high-priority alert. Monitor specifically for non-traditional tools like SimpleHelp and Nezha, which ransomware groups are adopting to evade detections tuned to more well-known platforms like AnyDesk or ConnectWise.

Top Tactics Targeting Enterprise Environments

In this section, we look into key MITRE tactics and techniques shaping attacker behavior this reporting period.

ClickFix and Spearphishing Lead Initial Access

Initial access was dominated by two familiar vectors at near-equal share and one new entry, all highly likely amplified by to US tax-season targeting. **Drive-by compromise** led at **27%**, driven largely by ClickFix as detailed in the malware section above. **Spearphishing** continued at elevated levels, with spearphishing attachments and spearphishing links combining to represent over **27%** of initial access activity, effectively matching drive-by compromise. We're highly confident that this surge is primarily driven by tax season, which creates a window of opportunity that attackers can consistently exploit. When users expect financial documents, compliance notices, and business statements, scrutiny likely drops and click rates rise.

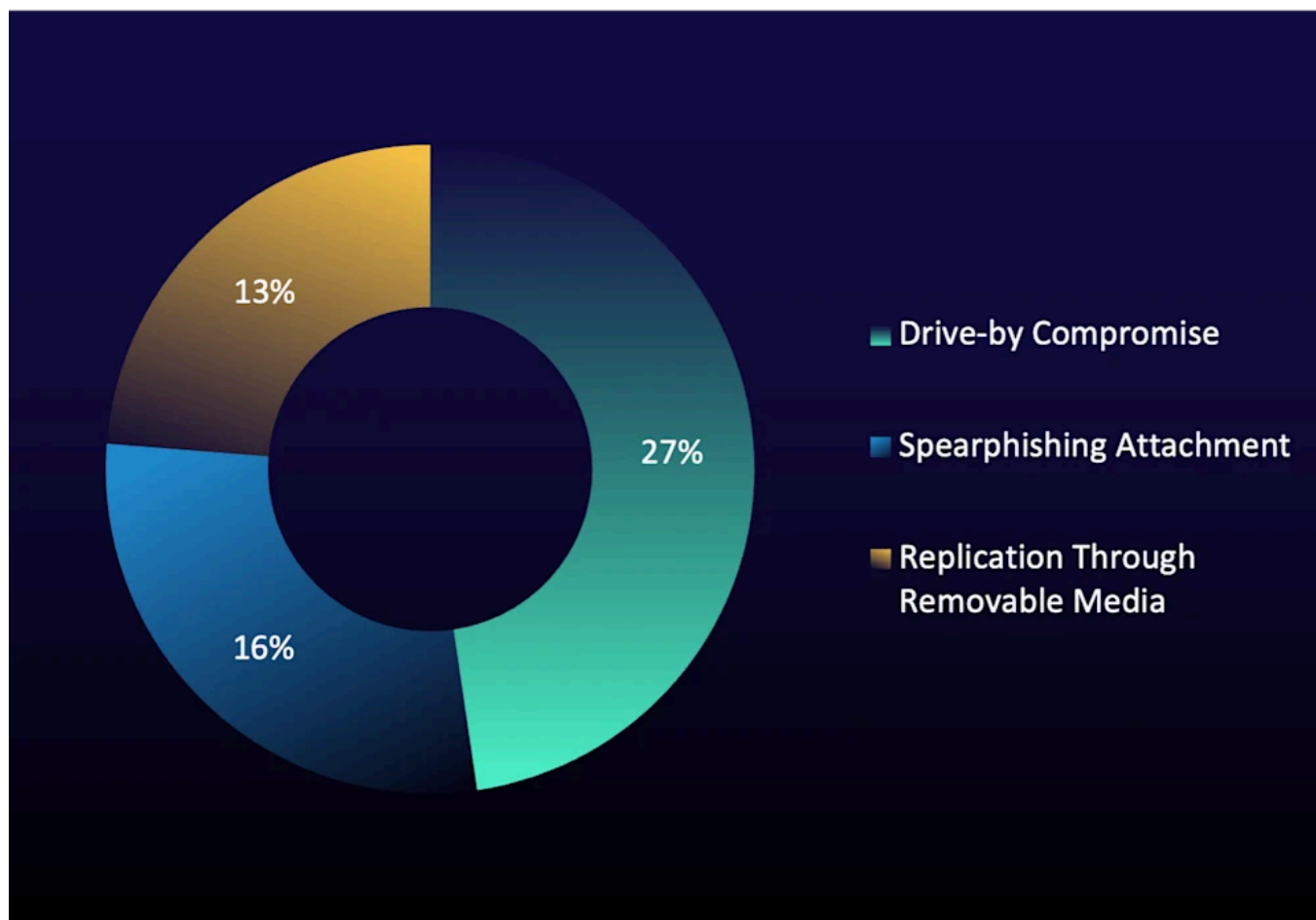


Figure 3: Top MITRE ATT&CK initial access techniques in true-positive incidents (% of total) during reporting period

Phishing lures increasingly used credential harvesters and weaponized documents built around business-themed pretexts designed to manufacture urgency. [In one repeatable campaign](#) we tracked across multiple incidents, attackers used Windows screensaver (.scr) files disguised as business and tax documents to bypass controls tuned for .exe and .msi extensions and then silently installed RMM agents upon execution. This playbook scales easily by swapping lure themes and hosting infrastructure.

Replication through removable media has returned to the top three after dropping out last period, which suggests that the “seasonal USB” [pattern we noted in Q2 2025](#) is recurring rather than a one-time anomaly. We assess tax season contributes here as well, as employees moving financial records between home and corporate systems often reuse personal USB devices that may already be infected. USB-borne malware typically propagates through malicious .lnk files or autorun exploits placed on drives by commodity worm families, which then execute automatically or through user interaction when the drive is connected to a new host. This period, we observed infections tied to both “**Gamarue**” and “**Raspberry Robin**.”

Raspberry Robin in particular is often used to broker access for ransomware operators, turning a single infected USB into a direct path to encryption and extortion.

USB-borne threats persist because many organizations still lack strict removable media policies. Disable USB autorun on all endpoints, enforce device allowlists for removable media, and configure endpoint monitoring to detect .lnk-triggered execution from external drives, especially during predictable periods of USB reuse.

Command Obfuscation and Masquerading Drive Defense Evasion

Hidden artifacts ranked first at **16.1%**, with **obfuscated files or information** at **14.6%** and **command obfuscation** at **13.4%**. Unlike last period's fragmented three-way split across unrelated techniques, this period's top evasion techniques are all mechanistically linked to ClickFix execution chain. When users paste ClickFix commands, resulting PowerShell or cmd processes typically execute in hidden windows to prevent the victim from seeing the malicious activity, while the underlying payloads are heavily obfuscated to evade detection. Together, these three techniques account for **more than 44% of defense evasion activity** this period. We've already covered ClickFix-driven delivery in the sections above, so we focus now on the masquerading trend, which we assess carries broader strategic implications for defenders.

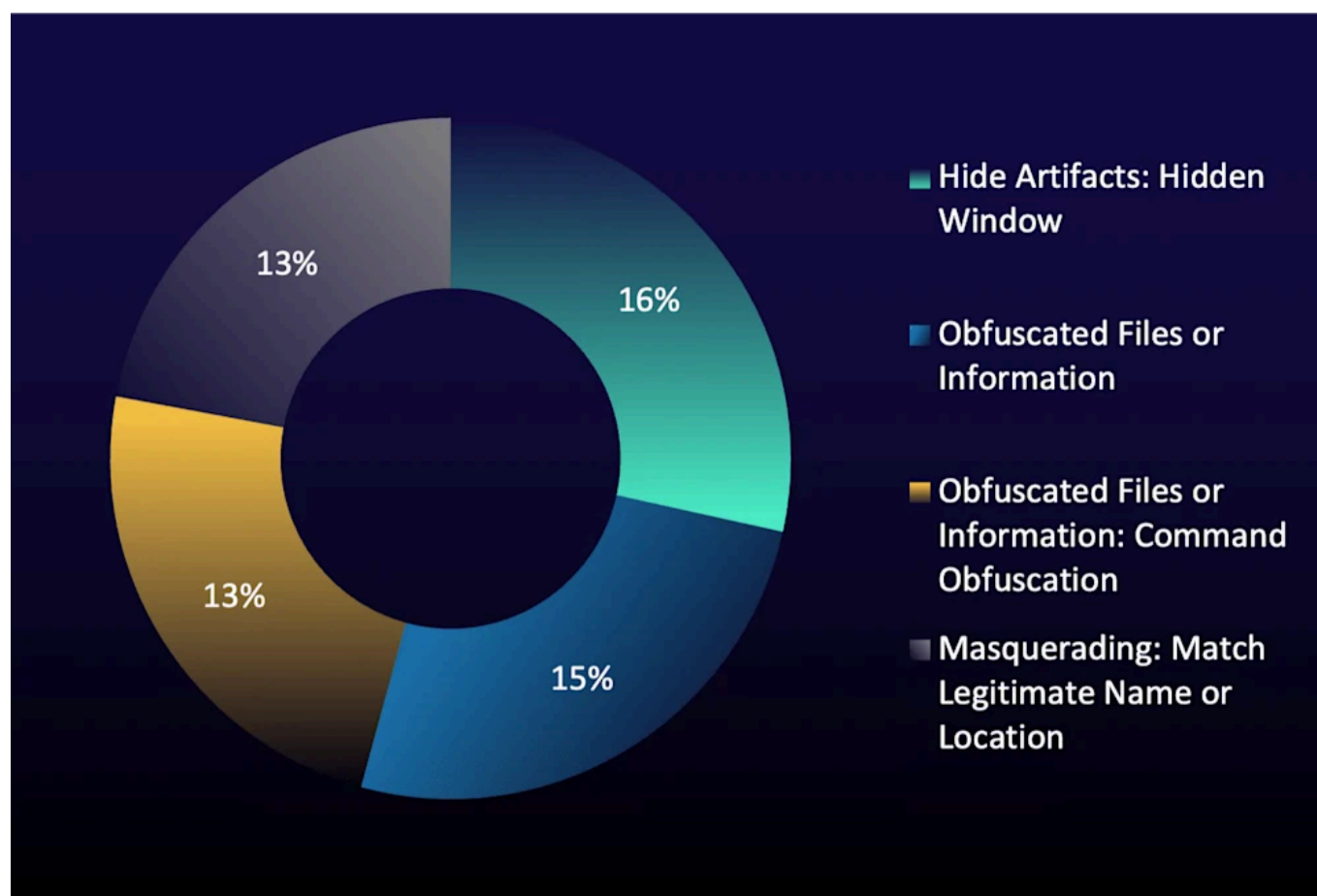


Figure 4: Top MITRE ATT&CK defense evasion techniques in true-positive incidents (% of total) during reporting period

Masquerading featured heavily this period at **12.5%**. In one incident that [we investigated in December](#) 2025, attackers manipulated a legitimate, digitally signed EDR executable to load malicious code through Dynamic Link Library (DLL) sideloading. As a result, the activity is indistinguishable from normal security software behavior. This technique doesn't exploit or bypass the EDR product itself; it abuses trust in signed, legitimate processes to conceal reconnaissance, C2 communications, and persistence. Standard remediation such as agent reinstalls or patching won't remove the attacker's foothold, which allows threat actors to progress further into the attack chain undetected by defenders.

This type of masquerading is likely to become more prevalent as organizations increasingly adopt AI-driven tools for alert evaluation and triage. A signed security process may look routine at first glance, and without an agentic solution trained to dig deeper into process lineage, loaded DLLs, and behavioral context, both analysts and automated systems can reasonably misclassify activity as benign. Masquerading against trusted security tools is, in effect, an anti-AI tactic that targets the assumptions baked into automated triage workflows.

Well-known extortion group ShinyHunters also used notable evasion tactics this period, including **mobile-device lure engagement**, which reduces visibility in corporate DNS and proxy telemetry, and hidden subdomain infrastructure that bypasses traditional “new domain” monitoring controls. These shifts help the group maintain effectiveness against large enterprises despite stronger user security awareness.

These incidents demonstrate that organizations must implement DLL load monitoring for security software processes, investigate anomalous module loads even from signed executables, and ensure that AI-driven triage solutions are configured to evaluate behavioral context rather than relying on process reputation alone.

Lateral Movement Splits Across On-Premises RDP and Cloud SSO Abuse

Lateral movement this period stayed anchored in traditional on-premises remote services. At the same time, ShinyHunters highlighted a distinct cloud-based lateral movement model through SSO session abuse. These paths create different operational challenges and require different defensive approaches.

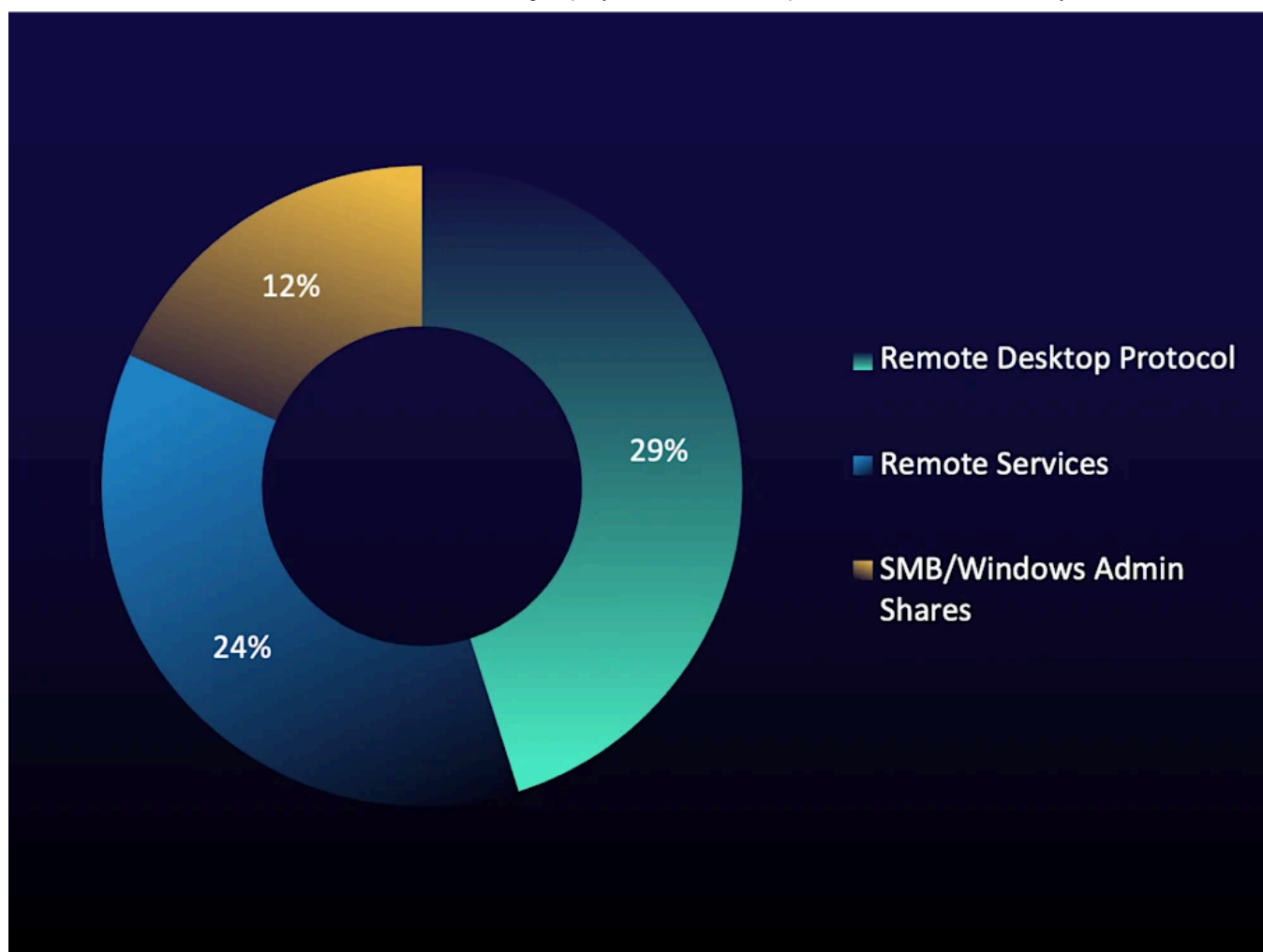


Figure 5: Top MITRE ATT&CK lateral movement techniques in true-positive incidents (% of total) during reporting period

On-Premises Remote Services Still Dominate

The top three lateral movement techniques—Remote Desktop Protocol (RDP), general remote services, and Server Message Block (SMB)/Windows Admin Shares—all (unsurprisingly) retained their positions from the last reporting period. These are ironclad tactics that have dominated lateral movement for years, and there is little reason to expect that to change.

RDP at approximately **29%** represents a modest recovery from last period's 25%—potentially due to the normalization of Akira and Qilin's heavy reliance on RDP following their VPN compromise chains—but well below the **54%** observed in the June–August 2025 report, suggesting some structural hardening. RDP remains popular because it exists in every Windows environment, is used daily by administrators, and provides low-friction, authenticated, legitimate-looking access once a privileged account is compromised. Nearly every ransomware group we track uses it, and it will continue to dominate as long as environments allow unrestricted RDP sessions and without strong authentication controls and anomaly monitoring.

General remote services accounted for roughly **one in four** lateral movement observations. This category captures the variety of protocols attackers leverage beyond RDP. Windows Remote Management (WinRM), Secure Shell (SSH), and distributed component object model (DCOM) each appeared at about 6%, reinforcing that attackers are opportunistic. When RDP is locked down or monitored, they pivot to whatever remote service protocol is available and receiving

less scrutiny. This means, hardening RDP without addressing SSH, WinRM, and DCOM leave alternative lateral paths open.

SMB/Windows Admin Shares held at approximately **12%**, consistent with its role as a complement to RDP in ransomware operations. We've seen Akira in particular lean on SMB to deploy encryption remotely across network shares from a single compromised host. This approach bypasses endpoint protections on managed systems because the encryption activity originates from an already-compromised machine rather than executing locally on each target. With valid credentials and SMB access to shared drives, this approach is broadly reusable, and we assess that SMB-based remote encryption will likely remain a standard ransomware tactic.

ShinyHunters Highlights Cloud Pivoting Through Stolen SSO Sessions

In the cloud dimension, ShinyHunters introduced what amounts to a fundamentally different lateral movement model. Once a valid SSO session is captured through AiTM phishing, the attacker can pivot across an organization's entire SaaS ecosystem—email, file storage, HR platforms, customer relationship management (CRM) systems, code repositories—through just a single authenticated session. Essentially, this is the cloud equivalent of owning an on-premises application server. Except instead of moving host to host, the attacker moves app to app, and there are no network-layer indicators to trip over.

As we detailed in our February 2026 analysis of [ShinyHunters' subdomain impersonation campaign](#), the group doesn't need malware or encryption to create impact. One successful SSO session enables rapid “smash-and-grab” access to high-value data across all connected SaaS applications, often before defenders have any indication that a session has been compromised.

While on-premises remote services remained the dominant lateral movement pattern this period, ShinyHunters' use of compromised SSO sessions highlights the need to defend cloud identity pathways as well. On-premises, organizations must enforce MFA on RDP sessions, monitor for unusual lateral movement patterns, and restrict SMB traffic from unmanaged devices. In the cloud, prioritize compliant device policies, phishing-resistant MFA, centralized SaaS audit logging, and rapid session containment capabilities.

Step Up Your Defenses

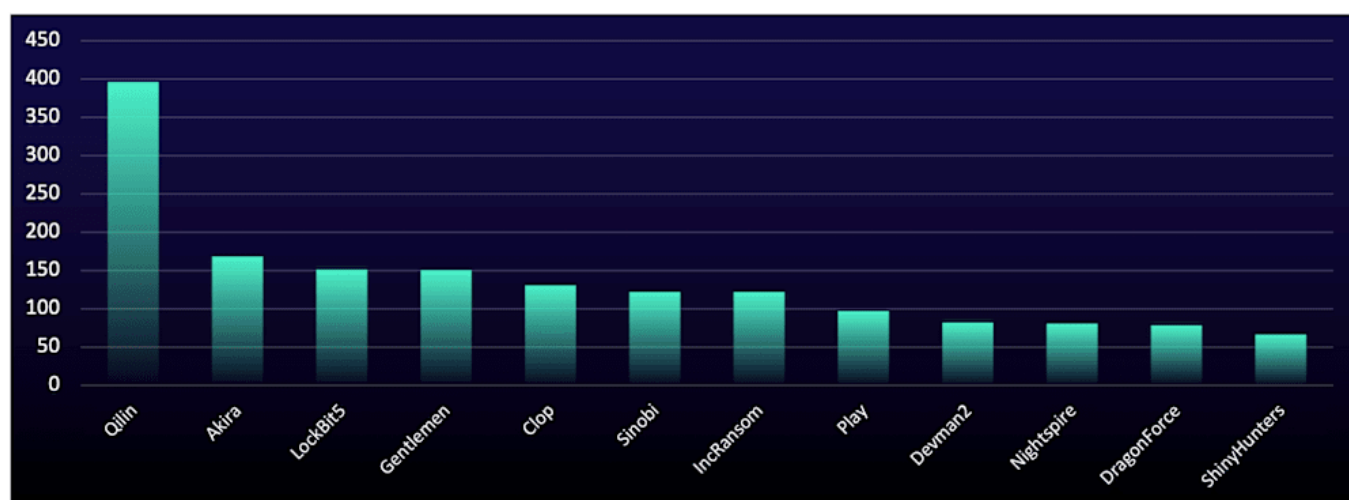
Lock Down User Execution Paths: Restrict Win+R access via Group Policy for standard users and block .scr file execution from user-writable locations. These two controls directly address the reporting period's top initial access techniques: ClickFix (which relies on the Run dialog) and the spearphishing campaign using screensaver files to deploy RMM agents.

Harden Both Lateral Movement Planes: On-premises, enforce MFA on all RDP sessions and restrict SMB traffic from unmanaged devices to disrupt the RDP-to-SMB encryption chain used by Akira and other ransomware groups. In the cloud, implement compliant device policies and phishing-resistant MFA for SSO-protected applications, and centralize SaaS audit logging to detect the app-to-app pivoting that SSO session abuse enables.

Extend Visibility to Mobile and Personal Devices: Enforce Conditional Access policies for Bring Your Own Device (BYOD) endpoints, limit sensitive SaaS access from personal devices, and ensure mobile sign-ins are logged and monitored with the same rigor as desktop sessions.

Top Ransomware and Extortion Groups

We tracked 12 major ransomware and extortion groups this reporting period. Of those, **Qilin**, **Akira**, and **ShinyHunters** stand out because they each operate different models while staying clear of zero-days or novel exploitation. Instead, they simply exploit well-understood gaps that organizations have struggled to close. These groups are succeeding because they win on speed, volume, and disciplined execution of proven tactics. Qilin and Akira remained the front runners from the previous reporting period, while ShinyHunters emerged this quarter due to its outsized impact on large enterprises through identity-first intrusions.



Qilin and Akira Hold Their Ground

Qilin was responsible for **24.1%** of victims named on data-leak sites, more than double second-place Akira. Its durability comes down to its strategy, as it deliberately targets small-to-medium-sized businesses rather than pursuing “big game hunting” like “Clop” or the now-disrupted “ALPHV.” This volume-first model drives a steady stream of ransom payments while avoiding concentrated law enforcement attention.

Akira held second at **10.2%**, continuing a VPN campaign active since mid-2025. Akira's edge is a repeatable, fast-moving playbook that involves exploiting unpatched appliances, moving laterally via RDP, and deploying ransomware against virtualization hosts, with [breakout times as fast as six minutes](#). That speed compresses the window defenders have to detect and respond, and is a direct product of how repeatable and standardized the playbook has become. Akira's victim count has remained steady rather than surging, but the group shows no signs of slowing as long as VPN appliances remain unpatched and unprotected by MFA.

ShinyHunters Proves Low Volume Can Still Mean High Impact

ShinyHunters accounted for **4%** of data-leak site listings, but its impact on individual enterprises was disproportionately high. The driving factor is a fundamentally different model, i.e., identity-first access through subdomain impersonation, phone-guided AiTM phishing, and SSO session

theft. As we explored earlier, one compromised session can open the door to a variety of systems, platforms and tools—all without deploying malware. The damage comes from data theft and extortion, not encryption.

What makes this model especially concerning is that ShinyHunters is outsourcing vishing tasks to paid contractors and reusing previously stolen SaaS records to build pretexts. This creates a repeatable access loop that can hit the same enterprise multiple times. As AiTM tools become more widely available, this identity-first approach is positioned to spread to other financially motivated groups.

Sector Targeting: Overall Victims Decline, But PSTS Concentration Grows

Overall, named victims on ransomware data-leak sites dropped approximately **25%** period-over-period, marking the **third consecutive period of decline**. The top five targeted sectors were largely unchanged from the previous period: professional, scientific, and technical services (PSTS), manufacturing, construction, health care, and a near-tie between finance and insurance and retail trade.

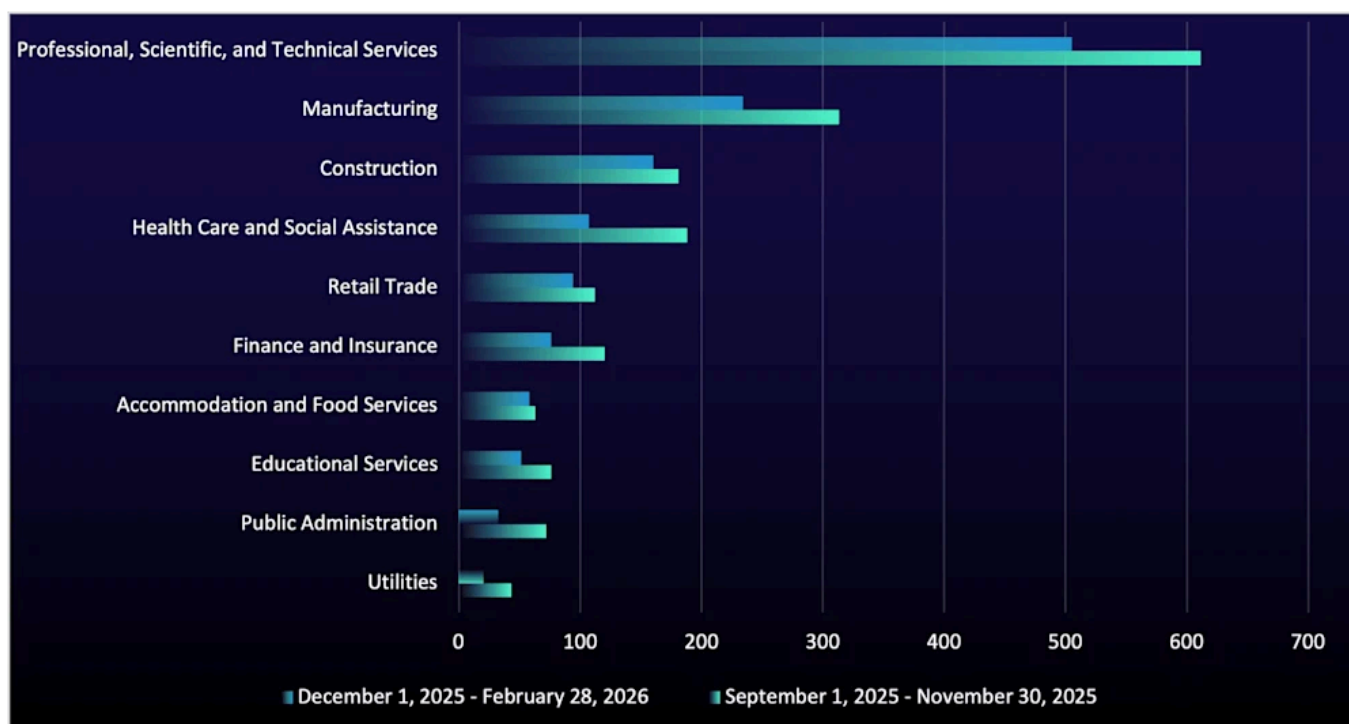


Figure 7: Organizations listed on ransomware data-leak sites, by sector, during this reporting period vs. the last reporting period

Step Up Your Defenses

Patch Internet-Facing Devices on Emergency Timelines: Treat VPNs, firewalls, and remote-access appliances as critical assets requiring emergency patching. If immediate patching isn't possible, isolate vulnerable systems until remediation is complete.

Test Backup and Recovery Under Realistic Conditions: Validate that offline backups are verified, ESXi/Hyper-V snapshot integrity is tested, and recovery procedures account for the

possibility that EDR agents have been disabled prior to encryption.

Implement Identity-First Containment for SaaS Environments: Deploy automated session termination and user-disabling playbooks that trigger on anomalous sign-ins, MFA re-enrollment from unrecognized devices, or bulk SaaS file downloads.

Key Takeaways and What's Next

The trends in this report are more likely to accelerate than stabilize. From BaoLoader's sustained dominance and trojanized ScreenConnect builds to EDR sideloading and ShinyHunters' SSO session theft, the common thread is that **attackers are systematically exploiting the tools, identities, and processes organizations already trust**. As a result, the gap between traditional indicator-driven defenses and attacker techniques designed to blend into legitimate activity will continue to widen. Organizations that don't adapt detection strategies to focus on behavioral anomalies over static signatures, extend monitoring into SaaS and identity telemetry, and treat internet-facing infrastructure as requiring emergency patch timelines will remain exposed to the same techniques that defined this period.

Three forecasts for the next reporting period:

The weaponization window for critical remote-access vulnerabilities will likely shrink to under one week. CVE-2026-1731 went from disclosure to confirmed ransomware exploitation within two weeks, a meaningful acceleration from the months-long timelines seen with vulnerabilities earlier in 2025. VPNs, remote support platforms, and RMM appliances remain among the highest-value targets for financially motivated actors, as one exploit can yield scalable, direct access into enterprise environments. As exploit development and operational playbooks continue to mature, we expect many future critical flaws in these technologies to be weaponized within days of disclosure, not weeks.

Identity-first intrusion models will likely spread beyond ShinyHunters. Although ShinyHunters accounted for only 4% of data-leak site listings this period, it showed that SSO session theft alone can produce outsized enterprise impact. The model is attractive because it reduces reliance on malware, privilege escalation, and noisy post-compromise activity. We assess that more financially motivated groups are likely to adopt AiTM phishing and session hijacking in the next reporting period, particularly as organizations continue centralizing access through SSO without equivalent investment in phishing-resistant MFA, session controls, and SaaS audit logging.

ClickFix will likely expand into collaboration platforms, starting with Microsoft Teams. Teams-based ClickFix activity this period suggests the technique is adapting to environments where users trust messages that appear to come from coworkers or internal contacts. This is an important shift because it bypasses traditional email security controls and exploits a channel where both detection coverage and user skepticism are often lower. If this pattern continues, collaboration platforms will become an increasingly effective delivery channel for social engineering-based initial access.

Read the ReliaQuest 2026 Annual Cyber-Threat Report

Built on thousands of incidents investigated in 2025, this report covers the full attack lifecycle—from social engineering and zero-day exploitation to AI-generated malware, ransomware fragmentation, and nation-state infiltration. Includes a CISO checklist and actionable recommendations for every major finding.

[Access The Full Report](#)



ReliaQuest Threat Research

The ReliaQuest Threat Research Team comprises SOC experts, security researchers, security practitioners, and intelligence analysts dedicated to bringing you the latest global analysis and essential updates within cyberthreat intelligence for your organization.

[Explore Blogs](#)



Your AI SOC Made Possible with ReliaQuest GreyMatter

Using your existing tool set, GreyMatter applies AI and automation to alert ingestion and provides automated alert containment, all within 5 minutes of detection.



Request A Demo

Join Our Upcoming Democast



RELIAQUEST®

Contact ReliaQuest

(800) 925-2159



Global Corporate Headquarters
1001 Water St
Suite 1900
Tampa, FL 33602

Solutions

Solution Overview

Eliminate Tier 1 and Tier 2

SecOps Metrics and Maturity

Multicloud and Multi-SIEM Environments

Securing Operational Technology

Platform

Attack Surface and Exposure Management

Dark Web and Digital Risk Protection

GreyMatter Agentic Teammates

Email Phishing Defense

SOAR & Automation

Security Data Pipeline

Mobile App

See Our Technology Partners

Product Releases

Learn

Resource Center

Blog

Threat Research

Customer Stories

Solution Briefs



[Digital Guides](#)[Research Reports](#)[ShadowTalk Podcast](#)[Videos](#)[GreyMatter Demos](#)[Webinars and Democasts](#)[Upcoming Events](#)[Cyber Knowledge](#)[GreyMatter FAQ](#)

Company

[Company](#)[No Show Dogs Podcast](#)[Make It Possible](#)[Careers](#)[Press and Media Coverage](#)[Become a Technology Partner](#)[Contact Us](#)[Report a Vulnerability](#)

[Privacy Policy](#)[ReliaQuest Platform and Support Agreement](#)

© 2026 ReliaQuest, LLC All Rights
Reserved